Grey Box VAPT (Network)

Prerequisites (Mandatory) - Linux Machine

Before starting, ensure:

1. Target Linux system is reachable from Nessus
2. **SSH (TCP 22)** is open
3. User has **root access** or **sudo privileges**
4. OS version is identified correctly

PART 1: Linux Local Patch Audit Using Nessus

Step 1: Create Scan

1. Login to Nessus
2. Go to **Scans** → **New Scan**
3. Select Credential Patch Audit
4. Enter:
   - **Name**: Linux Local Patch Audit – `<Hostname>`
   - **Targets**: Linux server IP / hostname

Step 2: Configure Linux Credentials

1. Open **Credentials** tab
2. Select **SSH**
3. Configure:
   - **Username**: root

     OR non-root user with sudo
   - **Authentication**:
     - Password **or**
     - SSH Private Key
4. If using non-root:
   - Enable ✔️ **Elevate privileges with sudo**
   - Enter sudo password

Step 4: Launch Scan

- Click **Save**
- Click **Launch**

PART 2: Policy Compliance Audit Using Nessus

Step 1: Create Compliance Scan

1. Go to **Scans** → **New Scan**
2. Select **Compliance** → **Policy Compliance Auditing**
3. Enter:
   - **Name**: Linux Configuration Audit – `<Hostname>`
   - **Targets**: Linux IP / hostname

Step 2: Upload Linux Audit File (.audit)

1. Go to **Compliance** tab
2. Select correct `.audit` file, for example:
   - CIS Ubuntu Linux 20.04 Benchmark
   - CIS RHEL 8 Benchmark
3. Ensure:
   - Audit file **matches OS version**
   - Server/workstation role is correct

Step 3: Configure SSH Credentials

(Same as patch audit)

- SSH credentials with root or sudo access
- Verify **privilege escalation is enabled**

Step 5: Launch Compliance Scan

- Click **Save**
- Click **Launch**

Prerequisites (Mandatory) - Windows Machine

Tool Used: HardeningKitty

---

1. Tool Deployment

HardeningKitty is deployed locally on the target Windows system using an approved PowerShell-based installation function.

The function dynamically retrieves the **latest stable release** from the official repository, extracts the module, and installs it into the system-wide PowerShell modules directory.

Installation Command Used:

```
FunctionInstallHardeningKitty() {$Version = (((Invoke-WebRequest"https://api.
github.com/repos/0x6d69636b/windows_hardening/releases/latest"-UseBasicParsin
g) |ConvertFrom-Json).Name).SubString(2)$HardeningKittyLatestVersionDownloadL
ink = ((Invoke-WebRequest"https://api.github.com/repos/0x6d69636b/windows_har
dening/releases/latest"-UseBasicParsing) |ConvertFrom-Json).zipball_url$Progr
essPreference ='SilentlyContinue'Invoke-WebRequest$HardeningKittyLatestVersio
nDownloadLink-Out HardeningKitty$Version.zipExpand-Archive-Path".\HardeningKi
tty$Version.zip"-Destination".\HardeningKitty$Version"-Force$Folder =Get-Chil
dItem .\HardeningKitty$Version |Select-Object Name-ExpandProperty NameMove-It
em".\HardeningKitty$Version\$Folder\*"".\HardeningKitty$Version\"Remove-Ite
m".\HardeningKitty$Version\$Folder\"New-Item-Path$Env:ProgramFiles\WindowsPow
erShell\Modules\HardeningKitty\$Version-ItemType DirectorySet-Location .\Hard
eningKitty$VersionCopy-Item-Path .\HardeningKitty.psd1,.\HardeningKitty.psm
1,.\lists\-Destination$Env:ProgramFiles\WindowsPowerShell\Modules\HardeningKi
tty\$Version\-RecurseImport-Module"$Env:ProgramFiles\WindowsPowerShell\Module
s\HardeningKitty\$Version\HardeningKitty.psm1"
}
InstallHardeningKitty
```

> The installation process does **not** modify any system security configuration and is limited to deploying the assessment module.
> refer to this github repo for latest resources: https://github.com/scipag/HardeningKitty

---

2. Audit Execution

After successful installation, the Windows policy compliance audit is executed locally using PowerShell with administrative privileges.

Audit Command Used:

```
Invoke-HardeningKitty-Mode Audit-Log-Report
```

---

3. Audit Behavior

The audit command performs the following actions:

- Executes **read-only configuration checks**
- Automatically selects applicable hardening benchmarks based on OS

- Evaluates local security policies, registry settings, and system configurations
- Generates audit evidence without applying any configuration changes

---

4. Output & Evidence Collection

The following artifacts are generated during execution:

- **Compliance Report (CSV)**
  `HardeningKitty-Report-<Hostname>.csv`
- **Execution Log File**
  `HardeningKitty-Log-<Hostname>.log`

These artifacts are preserved as **audit evidence** and used for reporting and remediation analysis.